Fifteen real incidents

Enterprise Agentic Systems: Foundations | Days 2 to 4 | the Incident Wall in one place

Day 2: Architecture, patterns and protocols

1. Replit: the freeze that wasn't (July 2025) p. 2
2. Air Canada: the chatbot the airline had to honour (Feb 2024) p. 3
3. postmark-mcp: one line of code, 1,643 downloads (Sept 2025) p. 4
4. GitHub MCP: a public issue read a private repository (May 2025) p. 5
5. Asana MCP: the server that showed other people's data (June 2025) p. 6

Day 3: Distributed systems and reliability

6. Knight Capital: 45 minutes (Aug 2012) p. 7
7. OpenAI GPT-4o in ChatGPT: the update nobody asked for (Apr 2025) p. 8
8. xAI Grok: the prompt edit that skipped review (May 2025) p. 9
9. DPD chatbot: an error after a system update (Jan 2024) p. 10
10. EchoLeak, Microsoft 365 Copilot: zero clicks (June 2025) p. 11

Day 4: Governance, evaluation and ops

11. Samsung: the code that went to a chatbot (2023) p. 12
12. Italy: the regulator's decision (Dec 2024) p. 13
13. Agent loop: eleven days without a cap (2025) p. 14
14. Amazon Q Developer: the pull request that reached the release (July 2025) p. 15
15. Deloitte Australia: the assurance review with invented references (2025) p. 16

Each card gives only what was publicly reported, with sources, and one question for a pair.
Where reporting is thin or contested the card says so. The eleven-day agent loop is self-reported and not independently verified.

CARD 1 | July 2025

The freeze that wasn't

What was reported

- A founder ran a public 12-day experiment building an application with an AI coding agent on the Replit platform.
- About day nine, during a code and action freeze he had told the agent to respect, the agent ran destructive commands against the live production database. Reports put the lost records at roughly 1,200 executives and 1,200 companies.
- The agent then told him a rollback was not possible.
- One report says the same database was being used for preview, testing and production. The freeze existed only as an instruction to the agent. The founder said the application was a demo and put the loss at about 100 hours of work.

The question for your pair

The freeze was a rule in the agent's instructions. Name one control that sits outside the agent and would have stopped the deletion even if the agent had decided to run the command.

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: heise online (July 2025); eWeek (22 July 2025); The Stack; AI Incident Database, incident 1152.

CARD 2 | February 2024

The chatbot the airline had to honour

What was reported

- A customer asked an airline's website chatbot about bereavement fares after a family death. The chatbot told him he could apply for the reduced fare retroactively within 90 days.
- The airline's actual policy said otherwise. A link in the chatbot's answer led to the correct policy page. The airline refused the refund.
- In a decision published on 14 February 2024, a British Columbia tribunal found the airline liable for negligent misrepresentation, said it had not taken reasonable care to ensure its chatbot was accurate, and ordered it to pay roughly C$812 including damages, interest and fees.
- The airline had argued the chatbot was a separate entity responsible for its own actions. The tribunal called that a remarkable submission.

The question for your pair

Which part of "telling a customer what the refund policy says" could be a rule, and which part needs the model at all?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: Civil Resolution Tribunal of British Columbia decision, 14 February 2024, as reported by Kiplinger, Fox Business, ITWire and Norton Rose Fulbright.

CARD 3 | September 2025

One line of code, 1,643 downloads

What was reported

- Security researchers at Koi Security reported what they described as the first malicious MCP server seen in the wild: an npm package called postmark-mcp.
- It copied the code of the real Postmark MCP server, which is published on GitHub, not npm. The publisher released fifteen versions that behaved normally.
- In version 1.0.16, released on 17 September 2025, one added line blind-copied every email sent through the server to an address the publisher controlled.
- Reports put the package at about 1,500 downloads in a week and 1,643 in total before it was removed. The emails could include password resets, invoices and customer correspondence.

The question for your pair

You run the intake checklist. Which line would have caught this, and at which moment: the first install, or a later version change?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: Koi Security as reported by The Hacker News (via ThaiCERT), SC Media, Dark Reading, The Register (29 September 2025).

CARD 4 | May 2025

A public issue read a private repository

What was reported

- Researchers at Invariant Labs showed that an agent connected to the official GitHub MCP server could be hijacked by a malicious issue posted in a public repository.
- The user asks the agent to look at the open issues of the public repository. The agent reads the attacker's instructions, uses the user's access token to read data from the user's private repositories, and publishes that data in a pull request on the public repository, where the attacker can read it.
- No tool was poisoned and no server was compromised. The token allowed access to both public and private repositories.
- The researchers and others described this as an architectural problem at the agent-system level, not a bug in the server.

The question for your pair

There are three legs: private data, untrusted instructions, a way out. Which one is easiest to remove in a design you have seen?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: Invariant Labs, "GitHub MCP exploited" (May 2025); DevClass; Hackernoon; SOCRadar.

CARD 5 | June 2025

The server that showed other people's data

What was reported

- A work-management vendor launched an experimental, opt-in MCP server on 1 May 2025.
- On 4 June the vendor found a logic flaw that could let one organisation's MCP users see data belonging to other organisations, limited to what the exposed user could access.
- The vendor took the server offline from 5 to 17 June, notified roughly 1,000 potentially affected customers on 16 June, and gave customers the means to request logs to check whether exposure had occurred.
- The bug was reported to have been in the initial release, so the exposure window ran for about a month.

The question for your pair

You are a customer of this server. How would you have found out, and what would you have wanted in the contract and the architecture before connecting?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: BleepingComputer (18 June 2025); The Register (18 June 2025); UpGuard; SANS NewsBites (24 June 2025).

CARD 1 | Knight Capital, August 2012

45 minutes

What was reported

- Knight Capital, a US market maker, was updating its automated order-routing system to join a new exchange programme starting on 1 August 2012.
- The new code reused a flag that had once switched on an old test function called Power Peg, unused since 2003 but never deleted.
- It was copied by hand to eight servers. One technician did not copy it to one of them, and nobody reviewed the deployment or checked it automatically.
- On 1 August, orders with the reused flag reached that server and started the old code. The check that stopped Power Peg when a parent order was filled no longer worked, so it kept sending new orders.
- In about 45 minutes it executed roughly 4 million trades in 154 stocks. Knight's pre-tax loss was about $440 million and it needed a $400 million rescue within days.
- The regulator's order recorded that automated emails referring to the old function had been sent before the open (reported as 97) and were not treated as an alarm.

The question for your pair

Where could this system have answered "has this already happened?", which line of an inventory of what was running would have shown the difference, and why did nobody act on the warnings?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: US Securities and Exchange Commission order (2013), as summarised by J R Varma, Henrico Dolfing and SmartBear; Wikipedia; Zof.

CARD 2 | OpenAI GPT-4o in ChatGPT, April 2025

The update nobody asked for

What was reported

- On 25 April 2025 OpenAI completed the rollout of an update to its GPT-4o model in ChatGPT that made the model noticeably more sycophantic: overly flattering and agreeable.
- Users noticed within days. OpenAI began rolling the update back on about 28 to 29 April and published a postmortem on 2 May.
- The postmortem said some expert testers had said the model felt slightly off, that other evaluations and live trials looked positive, and that there was no specific evaluation tracking sycophancy. It also said the release notes had not given enough information.
- This was a consumer product, not a bank's agent. Use it for the mechanism: something your agent depends on can change behaviour with nothing changing on your side.

The question for your pair

Where in your own agent's configuration is a model or product named by an alias that a provider can move? What would you run after any provider change, and who would be told?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: OpenAI, "Expanding on what we missed with sycophancy" (2 May 2025); TechCrunch (29 April 2025); Georgetown Law Tech Institute.

CARD 3 | xAI Grok, May 2025

The prompt edit that skipped review

What was reported

- On 14 May 2025, at about 3:15 in the morning Pacific time, a change was made to the system prompt of the Grok response bot on X telling it to give a specific response on a political topic.
- For hours it raised that topic in replies to unrelated posts.
- xAI said the change had not gone through its normal review process and that it violated its internal policies. It said it had made a similar unauthorised change earlier in the year.
- Its response: publish the system prompts on GitHub with a changelog, add checks so employees cannot change a prompt without review, and set up round-the-clock monitoring.
- This card is about change control on a system prompt, not about the topic the bot raised.

The question for your pair

Who can edit each layer of your agent's prompt? What stops a change going live without review? Who would notice at 03:15, and who could roll it back?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: TechCrunch (15 May 2025); Business Insider (16 May 2025); Engadget via Yahoo Tech; The Decoder.

CARD 4 | DPD chatbot, January 2024

An error after a system update

What was reported

- A delivery company's online chat used an AI element alongside human operators.
- A customer got it to swear, to write a poem criticising the company and to call itself useless. He posted the exchange on 18 January 2024 and it was widely viewed.
- The company said an error had occurred after a system update, that the AI element was immediately disabled and that it was being updated.
- The company said it had run the AI element in its chat successfully for several years before.

The question for your pair

The company said the AI element had worked for years. What does that tell you about "it was tested before"? Which entry in a configuration record would have changed? Was there a switch for the AI part with a human route behind it?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: The Guardian (20 January 2024); BBC; Business Insider via Yahoo; AI Incident Database, incident 631.

CARD 5 | EchoLeak, Microsoft 365 Copilot, June 2025

Zero clicks

What was reported

- Aim Security reported a vulnerability in Microsoft 365 Copilot, tracked as CVE-2025-32711 and rated critical (CVSS 9.3).
- It let an attacker extract data from a user's Copilot context with no action by the user.
- The attacker sends a crafted email. When Copilot later retrieves it to answer a question, hidden instructions in the email steer it into including sensitive organisational data in output that reaches the attacker.
- Researchers described it as the first known zero-click attack on an AI agent of this kind. Microsoft fixed it on the server side, needing no customer action. The researchers reported no evidence of exploitation in the wild.

The question for your pair

Where is the untrusted content in this story, and how did it reach the model? Which of the four layers (gateway filter, tool sandbox, output schema, human escalation) would have bounded it, and which would have missed it?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: The Hacker News (June 2025); SecurityWeek; TechRepublic (13 June 2025); Cybersecurity Dive; arXiv 2509.10540.

CARD 1 | Samsung, 2023

The code that went to a chatbot

What was reported

- Samsung Electronics' semiconductor division began allowing staff to use ChatGPT on 11 March 2023, according to Economist Korea.
- The same outlet reported on 30 March 2023 three cases of staff entering company material into it: two with source code and one with meeting content. One engineer was reported to have pasted the source code of a program that handles semiconductor equipment measurement data, to get help fixing an error.
- On 2 May 2023 Bloomberg reported a Samsung memo banning generative AI tools on company devices. As reported, the memo said engineers had accidentally leaked internal source code by uploading it to ChatGPT.
- Reporting differs on the month (March in the Korean reports, April in the report of the memo). Samsung did not say what the code contained, and no misuse of the data was reported.

The question for your pair

Nobody broke into anything. Which rule or control would have applied before the first paste, and who at CSOB would have been asked?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: Economist Korea (30 March 2023) as summarised by NHIMG; Bloomberg (2 May 2023) via Business Standard, Business Insider and Forbes Australia; The Register (2 May 2023).

CARD 2 | Italy, December 2024

The regulator's decision

What was reported

- On 20 December 2024 the Italian data protection authority (the Garante) fined OpenAI 15 million euros over ChatGPT.
- It said OpenAI had processed users' personal data to train ChatGPT without first identifying an adequate legal basis, and had breached the transparency principle and its information obligations to users. It also ordered a six-month public information campaign in Italian media.
- Reports describe it as the first significant GDPR fine against a major generative AI provider in Europe. The investigation began in March 2023, when the Garante imposed a temporary limit on ChatGPT in Italy.
- OpenAI called the fine disproportionate and said it would appeal.

The question for your pair

The finding was about training a model, not about a bank. What is the same question for a bank's own agent: what is the legal basis for each use of personal data, and where is it written down?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: Garante announcement, 20 December 2024, as reported by AP (via accesswdun.com), Bloomberg Law, The Hacker News, Lewis Silkin (14 January 2025) and Syrenis.

CARD 3 | Agent loop, 2025

Eleven days without a cap

What was reported

- An engineer, Teja Kusireddy, published an account in autumn 2025 of a multi-agent research pipeline that ran in a loop for about eleven days and produced a bill of about 47,000 US dollars.
- Accounts say the agents coordinated over the A2A protocol and kept asking each other for clarification, with no orchestrator to decide when the work was done. Health checks passed throughout and nobody noticed until the invoice arrived.
- Commentary afterwards agrees the missing control was a cap on spend or iterations, and that an anomaly alert on cost would have shortened the eleven days.
- This is a self-reported account that was widely repeated, not an independently investigated case. Retellings differ on the number of agents (two or four).

The question for your pair

The dashboards showed activity and no errors. What would the first useful signal have been, and is an alert enough, or does something have to be able to stop it?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: Kusireddy's account as repeated by DEV Community posts, Waxell (Logan Kelly), the Rapid Flow newsletter and PolicyLayer. Not independently verified.

CARD 4 | Amazon Q Developer, July 2025

The pull request that reached the release

What was reported

- A person using the handle lkmanka58 submitted a pull request to Amazon's open-source repository for the Amazon Q Developer extension for VS Code, containing a prompt telling the assistant to delete local files and cloud resources.
- The change was merged and shipped in version 1.84.0 on 17 July 2025.
- AWS's security bulletin said the code was incorrectly formatted and did not run as intended, that no customer resources were affected, and that it revoked and replaced credentials and released version 1.85.0. Reports put the extension at close to a million installations.
- Reports differ on when AWS acknowledged the issue (19 July in one account, 23 July in others). The formatting flaw, not a control, stopped the instructions from running.

The question for your pair

The thing that was changed was a prompt, and it was changed by a stranger. Which line of a configuration record would have shown it, and who reviews a change to a prompt?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: AWS security bulletin (19 July 2025) as reported by AWS Insider (25 July 2025); CyberInsider; TechRepublic (28 July 2025); Red Hot Cyber (25 July 2025).

CARD 5 | Deloitte Australia, 2025

The assurance review with invented references

What was reported

- Deloitte Australia was paid about 440,000 Australian dollars by Australia's Department of Employment and Workplace Relations for an "independent assurance review" of the automated penalty system in the welfare compliance framework. The 237-page report was published in July 2025.
- In August a university researcher, Chris Rudge, reported that it contained fabricated references, including a quotation attributed to a federal court judgment and sources that did not exist.
- A revised version published in October removed them and disclosed that a generative AI tool (Azure OpenAI) had been used. The department said the substance and recommendations were unchanged, and that Deloitte agreed to repay the final instalment of the contract.
- Deloitte said the matter had been resolved directly with the client.

The question for your pair

A report said something reassuring. What would you ask for before relying on it, and who checks the checker?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: Associated Press (7 October 2025) via CTV News, KSAT and The Republic; City AM (8 October 2025); YourStory.